Compte rendu du TP 1

Ahmed Abdelhedi / Mahmoud Fourati

I–II. Objectif et environnement

Ce TP consiste à configurer un pare-feu Huawei, puis à vérifier son comportement face à différents trafics. Nous étudions le filtrage avec suivi d'état, la reconnaissance des applications, les limites du filtrage HTTPS sans déchiffrement et l'inspection TLS.

Le poste client utilise le pare-feu comme passerelle. Le trafic Internet traverse la zone *Trust*, puis la zone *Untrust*. Les outils employés sont le navigateur Web, Firefox pour les essais TLS, Wireshark et les commandes ping et ssh.

Tableau 1. Plan d'adressage du poste 4, d'après le sujet et les captures.

Équipement / interface	Adresse	Rôle / zone
PC client	192.168.10.204/24	Trust ; passerelle 192.168.10.4
Pare-feu GE0/0/0	192.168.10.4/24	Trust, administration
Pare-feu GE0/0/1	10.4.0.1/24	DMZ
Pare-feu GE0/0/2	40.4.0.1/24	Untrust
Pare-feu GE0/0/8	192.168.33.84/23	Untrust, sortie Internet
Passerelle Internet	192.168.33.254/23	Prochain saut du pare-feu

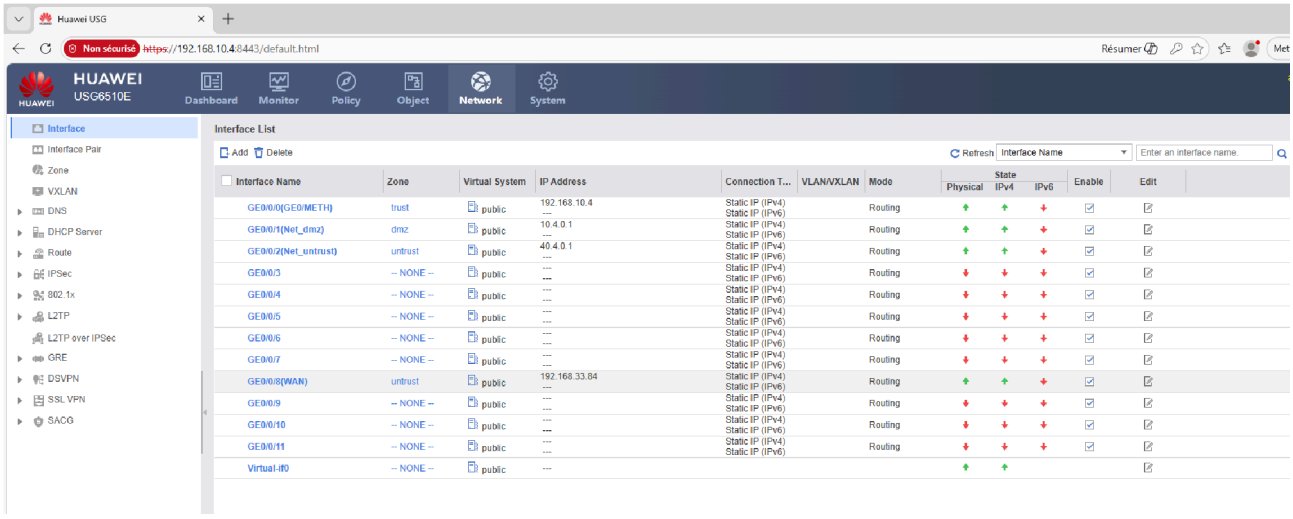


Figure 1. Interfaces et zones du pare-feu du poste 4. Source : captures du groupe [2].

Les interfaces utilisées pour la sortie Internet sont GE0/0/0 et GE0/0/8. Les interfaces DMZ et GE0/0/2 sont préparées pour les autres manipulations du laboratoire. L'administration est accessible à l'adresse https://192.168.10.4:8443.

Origine des captures. Les parties III à VI utilisent les captures de notre groupe, classées dans les dossiers p1 à p4 [2]. Les parties VII à XII sont complétées à partir des captures et du compte rendu du groupe de référence [3]. Les observations et les résultats attendus sont distingués lorsque la preuve du test n'est pas disponible.

III. Interconnexion du réseau

1. Route par défaut

Dans *Network > Route > Static Route*, la route 0.0.0.0/0 pointe vers 192.168.33.254, par l'interface GE0/0/8. Elle permet d'acheminer vers Internet les paquets qui ne correspondent pas à une route plus précise.

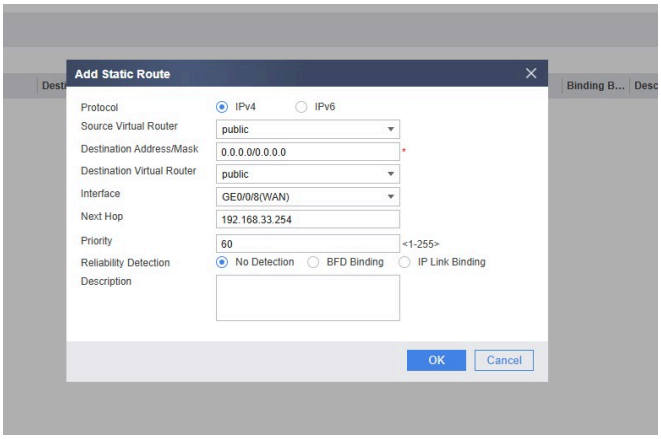


Figure 2. Route par défaut vers la passerelle Internet [2].

2. Traduction d'adresses source

Dans *Policy > NAT Policy*, la règle `Source-Nat` s'applique de *Trust* vers *Untrust*. Le mode choisi est *Source address translation*, avec traduction vers l'adresse de l'interface sortante : `192.168.33.84`.

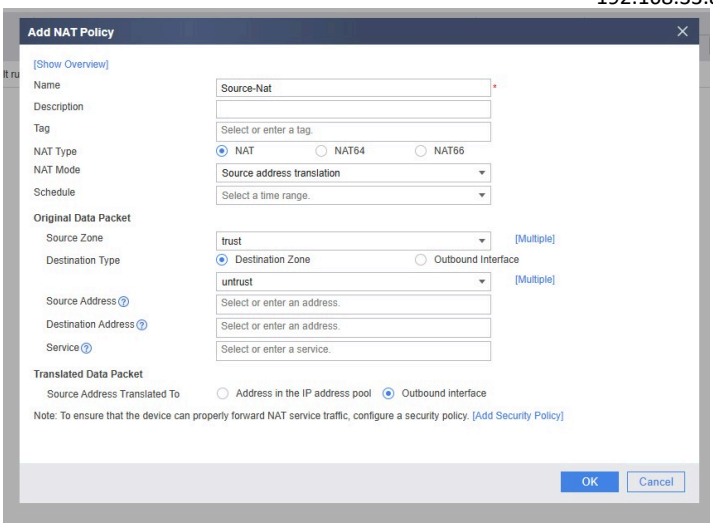


Figure 3. Règle Source-Nat et utilisation de l'adresse de sortie [2].

3. Autorisation initiale

La règle de sécurité `default` est d'abord réglée sur `Permit` afin de vérifier la connectivité avant d'appliquer les restrictions.

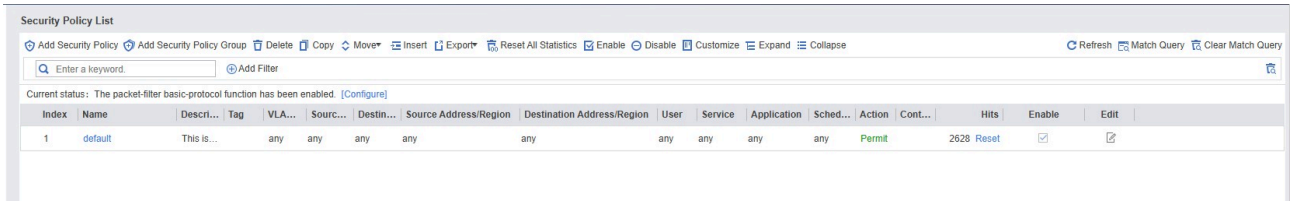


Figure 4. Politique par défaut autorisant le trafic pendant les premiers tests [2].

III. Vérification de la connectivité

4. Tests depuis le poste client

Le `ping 8.8.4.4` reçoit quatre réponses, soit 0% de perte. La page Portquiz est accessible sur le port 80. La connexion `ssh demo@test.rebex.net` aboutit et affiche l'invite du serveur Rebex.

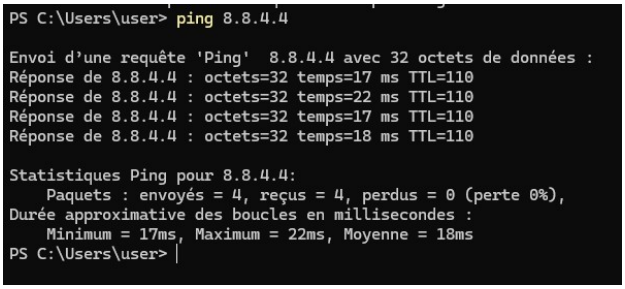


Figure 5. Réponses au ping vers 8.8.4.4 [2].

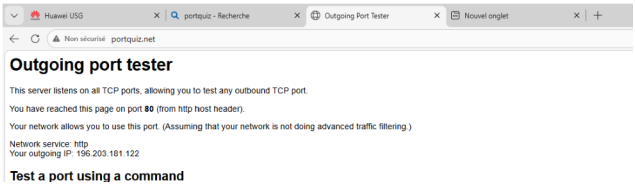


Figure 6. Accès HTTP à Portquiz sur le port 80 [2].

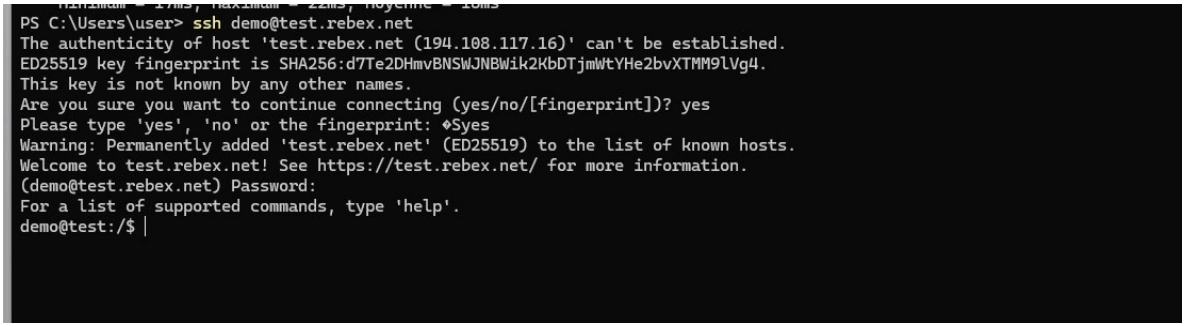


Figure 7. Connexion SSH au serveur test.rebex.net et authentification réussie [2].

5. Consultation des sessions

La table des sessions est consultée dans l'interface du pare-feu. La commande CLI équivalente demandée dans le sujet est :

display firewall session table verbose

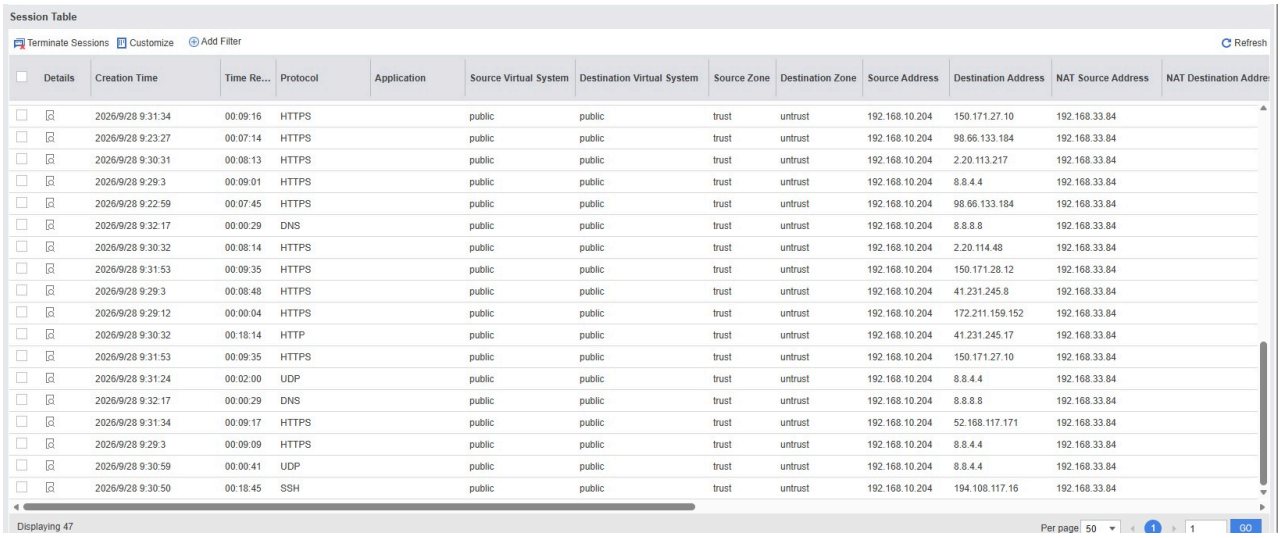


Figure 8. Sessions sortantes du client et adresse source traduite [2].

La capture montre des sessions de *Trust* vers *Untrust*, avec l'adresse du client $_{192.168.10.204}$ et l'adresse NAT $_{192.168.33.84}$. Les tests confirment que le routage, la résolution des noms et la sortie Internet fonctionnent dans cette configuration permissive.

IV. Filtrage de paquets avec suivi d'état

1. Politique de sécurité

La règle $_{default}$ passe à $_{Deny}$. Les autorisations deviennent explicites. Les règles particulières sont placées avant les règles plus générales afin que la première règle correspondante applique l'action voulue.

Tableau 2. Organisation du filtrage de Trust vers Untrust.

N°	Règle	Trafic visé	Action

1	deny-icmp-8.8.4.4	ICMP Echo-Request vers 8.8.4.4/32	Deny
2	allow-icmp	Autres échanges ICMP sortants	Permit
3	deny-portuiz	Destination : groupe de domaines Portquiz	Deny
4	allow1	DNS, SMB, FTP, HTTP et HTTPS	Permit
5	default	Tout trafic non autorisé par les règles précédentes	Deny

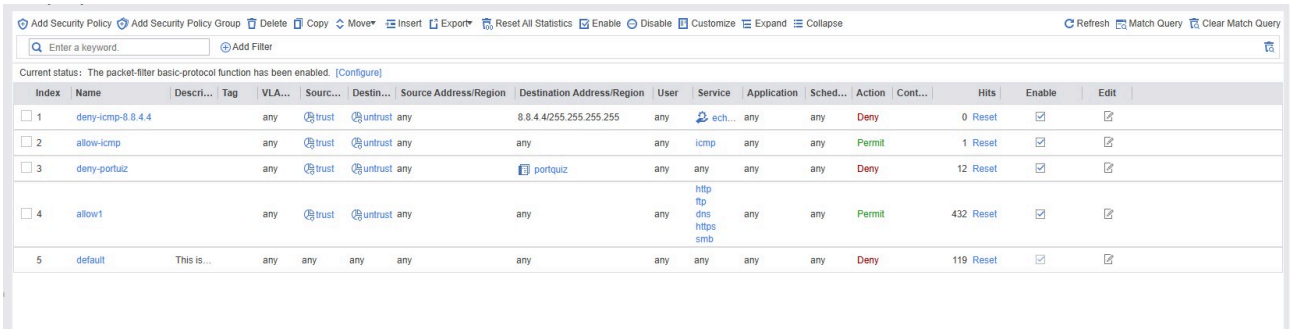


Figure 9. Liste des règles après restriction du service ICMP à Echo-Request [2].

2. Groupe de domaines et restriction ICMP

Le groupe portquiz contient www.portquiz.net. Il est utilisé comme destination de la règle de refus. La restriction vers 8.8.4.4 porte sur le service echo-request, comme demandé dans le sujet.

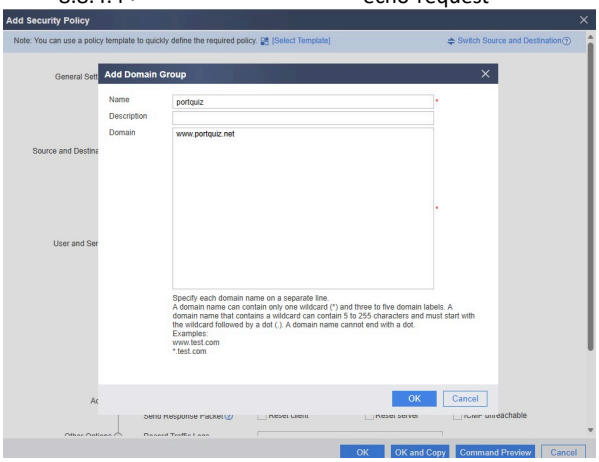


Figure 10. Création du groupe de domaines Portquiz [2].

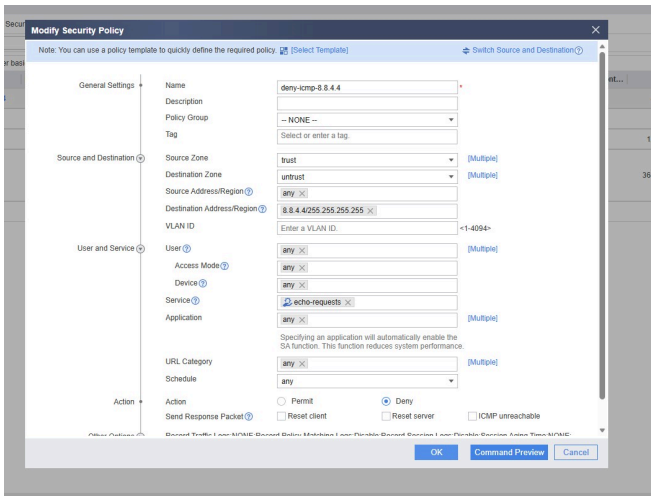


Figure 11. Refus des Echo-Request vers 8.8.4.4 [2].

Principe du suivi d'état. Le pare-feu conserve une table des communications autorisées. Les paquets de réponse appartenant à une session valide sont reconnus ; ils ne sont pas traités comme une nouvelle connexion entrante indépendante.

Lecture des captures. La liste ci-dessus refuse déjà Portquiz avec Service: any. L'accès sur 445 présenté en partie V correspond à un autre état des règles pendant les ajustements de la séance.

IV. Tests des règles de filtrage

Les tests comparent les flux autorisés et refusés après le passage de la politique par défaut à Deny.

```
PS C:\Users\user> ping 8.8.4.4

Envoi d'une requête 'Ping'  8.8.4.4 avec 32 octets de données :
Délai d'attente de la demande dépassé.
Délai d'attente de la demande dépassé.
Délai d'attente de la demande dépassé.
Délai d'attente de la demande dépassé.

Statistiques Ping pour 8.8.4.4:
    Paquets : envoyés = 4, reçus = 0, perdus = 4 (perte 100%),
PS C:\Users\user> ping 8.8.8.8

Envoi d'une requête 'Ping'  8.8.8.8 avec 32 octets de données :
Réponse de 8.8.8.8 : octets=32 temps=22 ms TTL=111
Réponse de 8.8.8.8 : octets=32 temps=19 ms TTL=111
Réponse de 8.8.8.8 : octets=32 temps=17 ms TTL=111
Réponse de 8.8.8.8 : octets=32 temps=17 ms TTL=111

Statistiques Ping pour 8.8.8.8:
    Paquets : envoyés = 4, reçus = 4, perdus = 0 (perte 0%),
Durée approximative des boucles en millisecondes :
    Minimum = 17ms, Maximum = 22ms, Moyenne = 18ms
PS C:\Users\user>
```

Figure 12. 8.8.4.4 ne répond plus, tandis que 8.8.8.8 reste joignable [2].

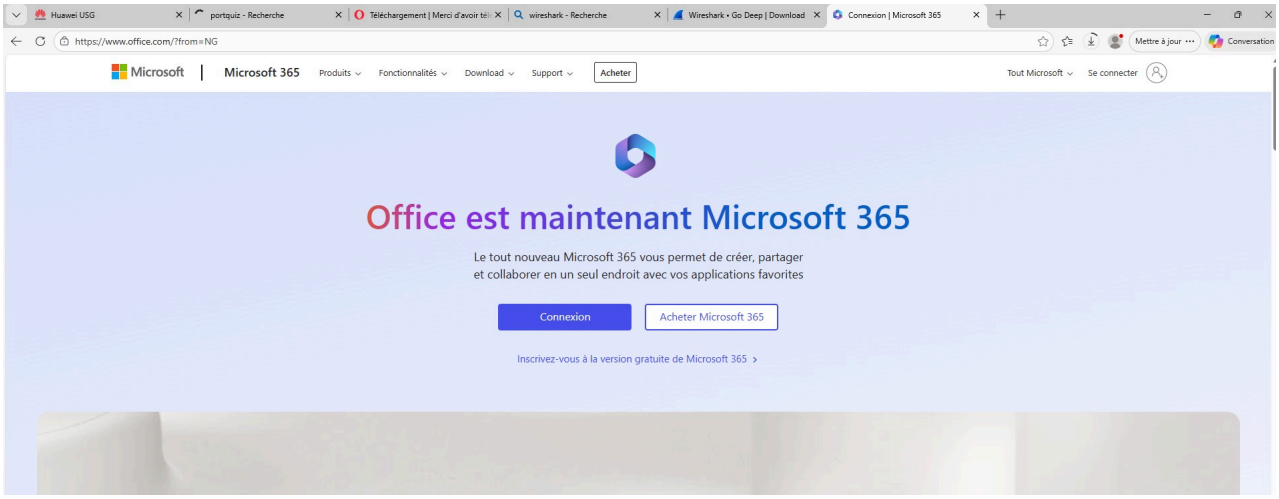


Figure 13. Accès à Office, redirigé vers Microsoft 365, par HTTPS [2].

```
PS C:\Users\user> ssh demo@test.rebex.net
ssh: connect to host test.rebex.net port 22: Connection timed out
```

Figure 14. La nouvelle tentative SSH vers Rebex expire [2].

Tableau 3. Résultats des essais de la partie IV.

Test	Résultat et interprétation
ping 8.8.4.4	4 requêtes, aucune réponse ; résultat cohérent avec la règle de refus.
ping 8.8.8.8	4 réponses ; les autres requêtes ICMP sont autorisées.
https://www.office.com	La page Microsoft 365 s'affiche ; HTTPS reste autorisé.
SSH vers Rebex (TCP/22)	Expiration de la connexion ; SSH ne fait pas partie des services autorisés.
Portquiz (HTTP)	La règle de refus est configurée ; les captures du navigateur montrant l'échec sont présentées en partie V.

Les compteurs de règles et les sessions permettent de compléter ces tests. Un délai dépassé, pris seul, ne permet toutefois pas d'identifier avec certitude la cause d'un refus.

V. Filtrage par port et identification applicative

Question 1. Portquiz est accessible sur TCP/445 dans l'essai initial. Le port 445 est habituellement utilisé par SMB, mais il peut transporter HTTP. Une règle fondée uniquement sur les ports ne reconnaît donc pas nécessairement l'application réelle.

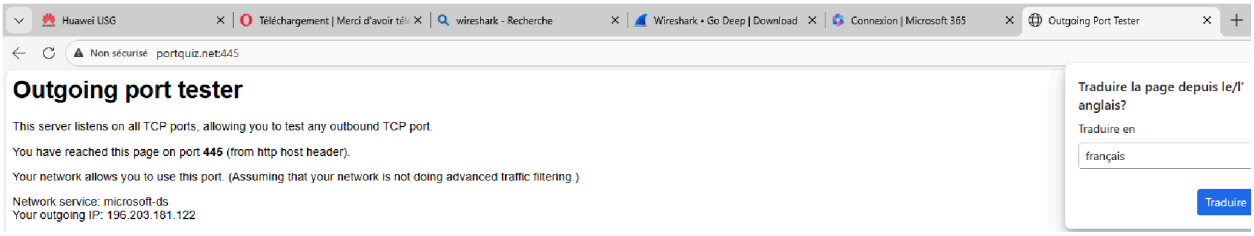


Figure 15. Portquiz indique explicitement un accès HTTP sur le port 445 [2].

Questions 2–3. La règle de refus sélectionne le groupe Portquiz, Service: any, Application: HTTP et l'action Deny. L'objectif est de refuser HTTP vers ce domaine quel que soit son port. Les deux essais du navigateur, sur 445 et sur le port HTTP standard, affichent ensuite une réponse vide.

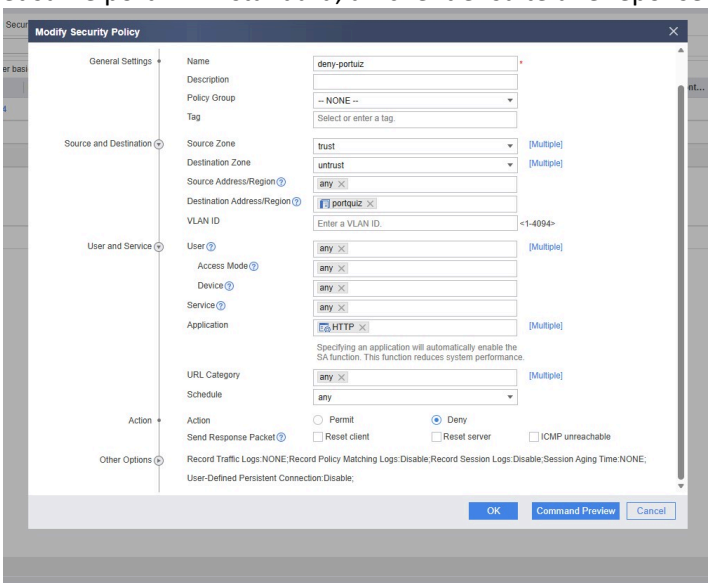


Figure 16. Identification HTTP sans restriction de port [2].

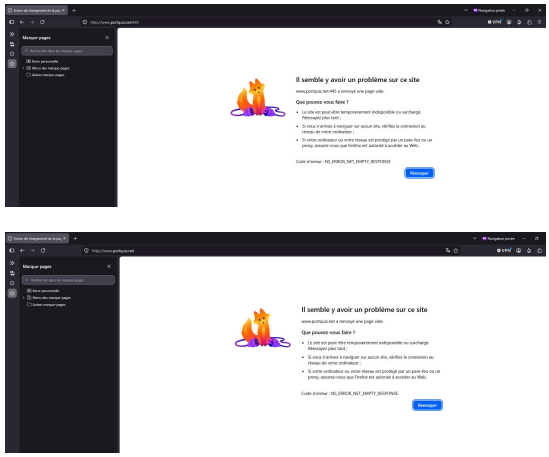


Figure 17. Échecs d'accès sur 445, puis sur le port standard [2].

Question 4 : analyse Wireshark. La trace montre successivement SYN, SYN, ACK, ACK, la requête GET / HTTP/1.1, puis RST.

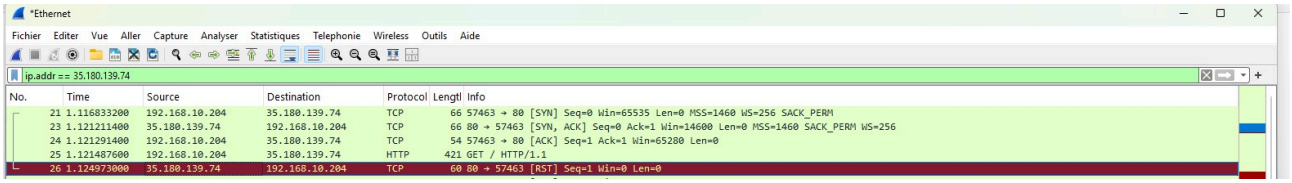


Figure 18. Établissement TCP, requête HTTP, puis réinitialisation de la connexion [2].

. La connexion TCP n'est pas bloquée immédiatement : le handshake aboutit.
. Le client envoie ensuite une requête HTTP, qui permet l'identification applicative.
. Un paquet RST apparaît juste après cette requête ; la connexion est interrompue.
. Un filtrage par port peut décider dès le premier paquet. Le filtrage applicatif peut attendre les premières données pour identifier HTTP, même sur un port inhabituel.

La séquence est cohérente avec un refus applicatif. Le journal de la règle serait nécessaire pour attribuer formellement le RST au pare-feu.

VI. Filtrage HTTPS sans déchiffrement TLS

Question 5 : profil URL. Dans le profil de filtrage, *Filter Encrypted Traffic* est activé. La liste noire contient l'URL www.thinkbroadband.com/tools/what-is-my-ip et l'hôte www.yahoo.com. Ce profil doit être associé à la règle de sécurité qui autorise le trafic Web sortant.

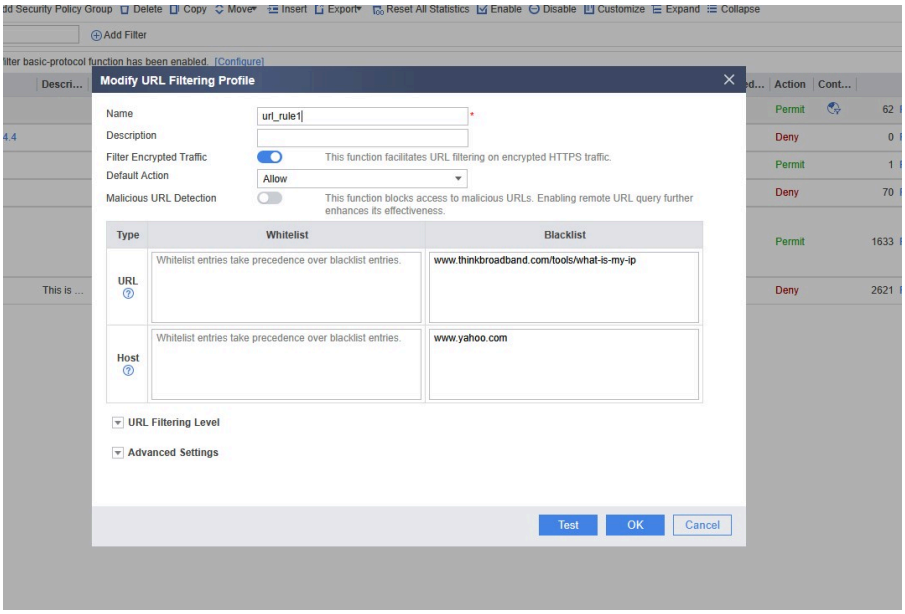


Figure 19. Liste noire d'URL et d'hôtes, avec filtrage du trafic chiffré activé [2].

Questions 6–7 : échange avec ThinkBroadband. Sans déchiffrement, le résultat attendu est que la page ThinkBroadband reste accessible : son chemin n'est pas visible dans TLS. La capture montre un handshake suivi de données applicatives. Le paquet *Client Hello* est repérable avec le filtre Wireshark tls.handshake.type == 1. Son SNI vaut www.thinkbroadband.com.

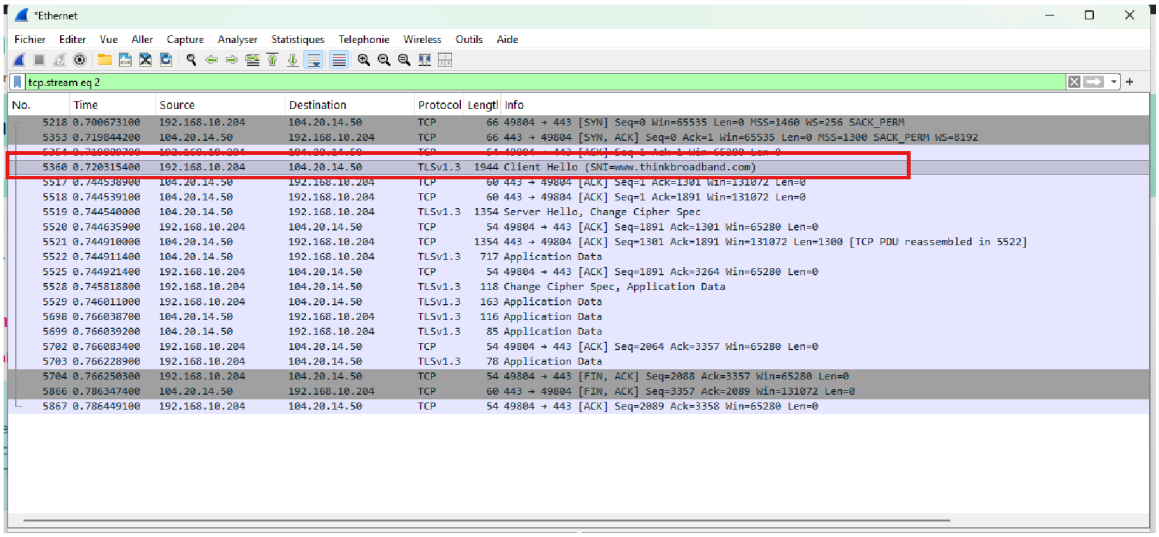


Figure 20. Client Hello de ThinkBroadband : nom du serveur visible dans le SNI [2].

Question 7c. Le chemin /tools/what-is-my-ip ne fait pas partie du SNI. Il est inclus dans la requête HTTP chiffrée et n'est pas lisible dans cette capture réseau. La trace établit la présence d'échanges TLS ; elle ne montre pas, à elle seule, le rendu de la page dans le navigateur.

VI. Données chiffrées et comparaison avec Yahoo

Question 8. Après le handshake, Wireshark affiche Application Data et Encrypted Application Data, à la place d'une requête HTTP et d'un chemin URL lisibles. La mention du protocole HTTP dans le détail du paquet ne signifie pas que son contenu a été déchiffré.

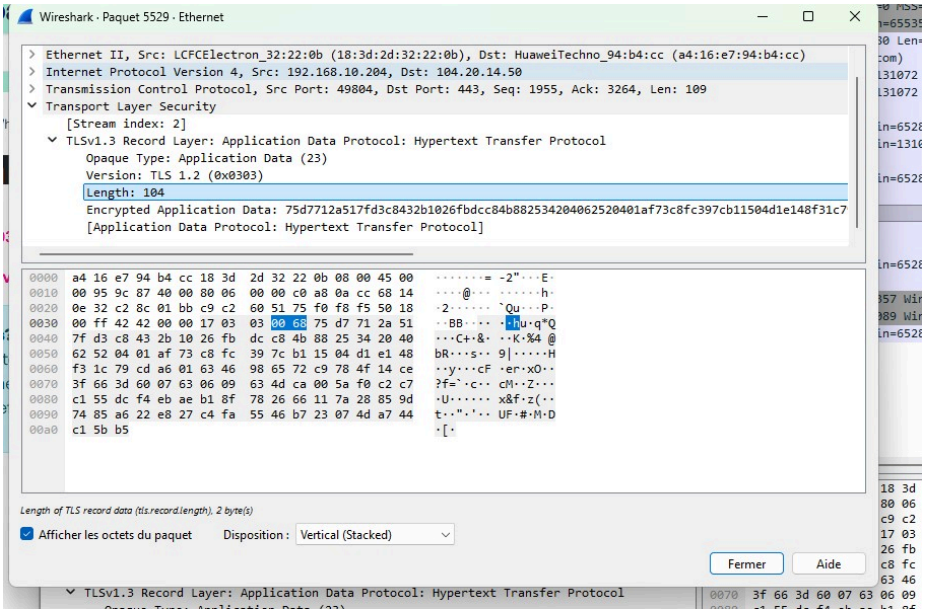


Figure 21. Données applicatives TLS chiffrées dans la capture du groupe [2].

Questions 9–10. Dans la trace Yahoo, le *Client Hello* indique SNI=yahoo.com. Cette valeur est celle réellement visible, même si le sujet demande de visiter www.yahoo.com. La trace montre ensuite une réponse HTTP/1.1 503 Service Unavailable, puis des paquets RST. L'accès n'aboutit pas normalement ; cette capture seule ne donne pas le motif exact de la décision du pare-feu.

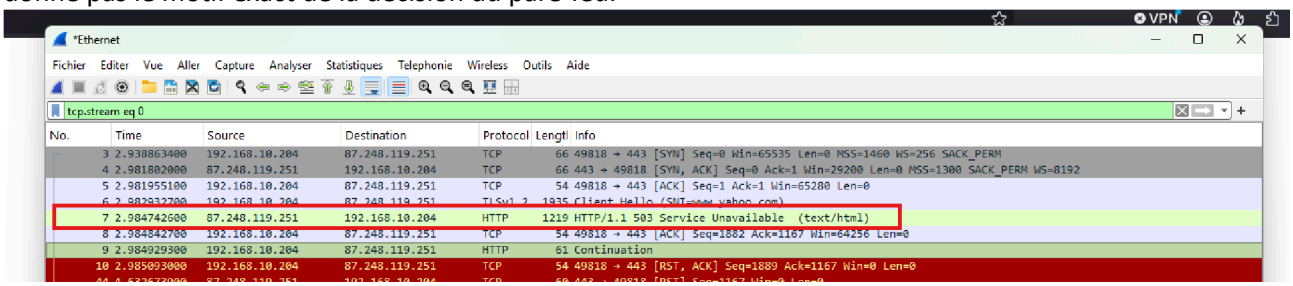


Figure 22. Essai Yahoo : SNI, réponse 503 et interruption de la connexion [2].

Question 11. Dans les échanges observés, le SNI est visible avant le chiffrement des données applicatives. Le pare-feu peut donc filtrer un nom d'hôte. En revanche, le chemin de la page et le contenu HTTP restent chiffrés : ils ne peuvent pas être inspectés de la même manière sans déchiffrement TLS.

Tableau 4. Informations disponibles sans déchiffrement, pour les traces étudiées.

Visibles	Protégées dans le trafic TLS
Adresses IP, ports, SNI du Client Hello	Chemin URL, en-têtes HTTP et contenu transféré

L'option *Filter Encrypted Traffic* ne constitue pas, à elle seule, une activation du déchiffrement TLS.

VII. Déchiffrement TLS et inspection HTTPS

À partir de cette partie, les captures proviennent du groupe de référence [3]. Le principe consiste à établir deux sessions TLS : une entre le client et le pare-feu, l'autre entre le pare-feu et le serveur. Le pare-feu déchiffre les données, applique les contrôles, puis les rechiffre.

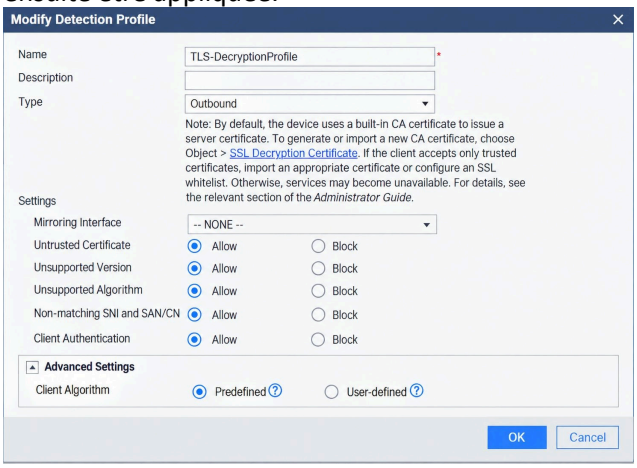
Question 12 : certificat d'inspection. Le sujet demande de générer une CA dans *Object > Certificates > SSL Decryption Certificate*, avec les paramètres ci-dessous. Les captures de certificats présentées ensuite confirment le nom de la CA utilisée ; elles ne montrent pas tous les paramètres de sa création.

Tableau 5. Paramètres de la CA d'inspection demandés par le sujet [1].

Paramètre	Valeur
Nom du certificat	SUPCOM_SSL_Inspection_CA

Common Name	SUPCOM-USG-SSL-Inspection-CA
FQDN	security-lab.supcom.tn
Organisation / unité	SUP'COM / Cybersecurity Lab
Pays / localité	TN / Tunis
Algorithme / taille / validité	RSA / 4096 bits / 365 jours

Questions 13–16 : profil et politique. Le profil de détection est de type `Outbound`. La politique vise *Trust* vers `Untrust`, le service HTTPS et l'action `Decrypt`. Le profil créé lui est attaché ; la configuration doit ensuite être appliquée.



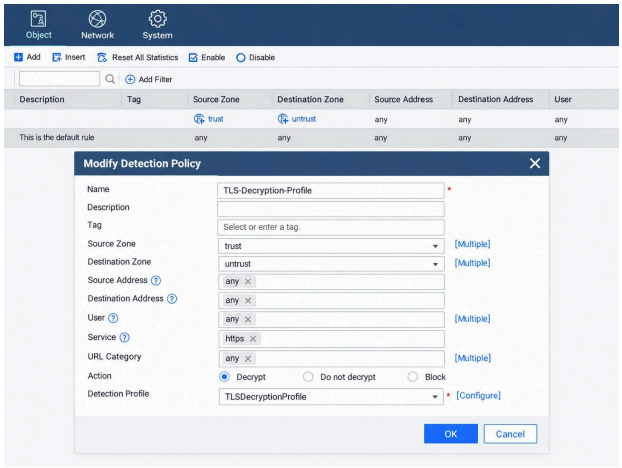


Figure 23. Profil de détection sortant [3]. **Figure 24.** Politique HTTPS avec action Decrypt [3].

VIII. Compatibilité du client TLS

Question 17. La manipulation demandée est d'ouvrir `about:config` dans Firefox, de régler security.tls.enable_kyber sur `false`, puis de redémarrer le navigateur. Aucune capture de ce réglage n'a été fournie.

Question 18. Le pare-feu participe lui-même aux négociations TLS. S'il ne prend pas en charge un mécanisme hybride X25519/ML-KEM proposé par le navigateur, la connexion peut échouer même si le navigateur et le serveur seraient compatibles en accès direct. La compatibilité doit donc être assurée sur les deux sessions TLS.

IX. Interception TLS, certificats et HSTS

Questions 19–20. Lors de l'accès à `https://neverssl.com/`, le certificat présenté au navigateur est réémis par le pare-feu. Le visualiseur de certificats permet de relever son sujet et son émetteur.

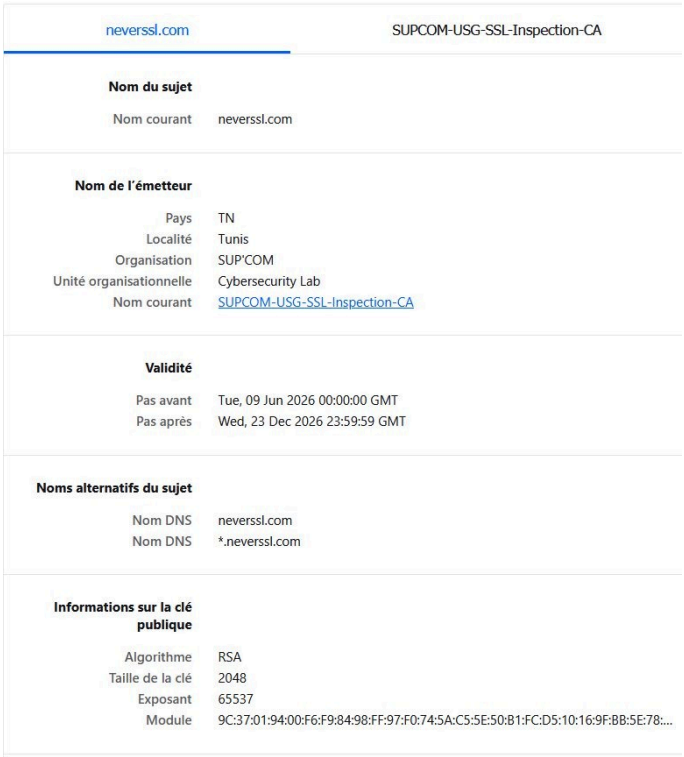


Figure 25. Certificat de neverssl.com émis par la CA d'inspection SUPCOM [3].

Tableau 6. Identification du certificat reçu par Firefox.

Champ	Valeur / rôle
Subject	neverssl.com ; noms alternatifs : neverssl.com et *.neverssl.com
Issuer	SUPCOM-USG-SSL-Inspection-CA
Chaîne d'inspection	Certificat du site réémis, puis CA d'inspection SUPCOM ; les deux certificats sont proposés dans le visualiseur.

Questions 21–22. Le certificat reçu n'est pas directement signé par l'autorité publique habituelle du site. Son émetteur est la CA locale SUPCOM-USG-SSL-Inspection-CA·

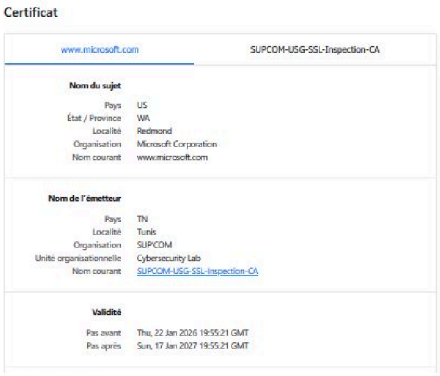
Question 23. Avant l'importation de cette CA, Firefox ne possède pas l'autorité de confiance nécessaire pour valider le certificat réémis. Un avertissement de confiance est donc attendu ; la capture fournie montre le certificat, pas l'avertissement initial.

Question 24 : rôle de HSTS. Pour un domaine soumis à HSTS, tel que Google dans le test demandé, Firefox impose HTTPS et n'autorise pas de contournement de l'erreur de certificat par une simple exception. La CA d'inspection doit être reconnue par le navigateur. Ce comportement est la réponse attendue du TP ; aucune capture du refus d'exception Google n'est fournie.

X. Confiance dans la CA d'inspection

Questions 25 et 27 : export et import. On exporte uniquement le certificat public de la CA du pare-feu. Dans Firefox, on l'importe via *Paramètres > Vie privée et sécurité > Certificats > Afficher les certificats > Autorités*, en activant la confiance pour identifier les sites Web. La clé privée de la CA reste sur le pare-feu.

Question 26. Le pare-feu utilise la clé privée de sa CA pour signer les certificats de substitution. Le client utilise la clé publique contenue dans le certificat de cette CA pour vérifier les signatures. Il n'a pas besoin de la clé privée.



Questions 28a–c. Le certificat Microsoft affiche comme émetteur SUPCOM-USG-SSL-Inspection-CA. Le même émetteur est attendu pour Google si sa connexion est également inspectée. Le certificat Google n'est pas montré dans les pièces fournies.
Après importation, Firefox accepte les certificats valides signés par cette CA car celle-ci est devenue une autorité de confiance du navigateur.

Figure 26. Sujet et émetteur du certificat Microsoft, extrait de la capture [3].

Question 29 : nouveaux tests. Les deux captures suivantes affichent *Web Access blocked* et *Blocked Type: blacklist*. Le refus vise cette fois l'URL complète de ThinkBroadband, ainsi que Yahoo.

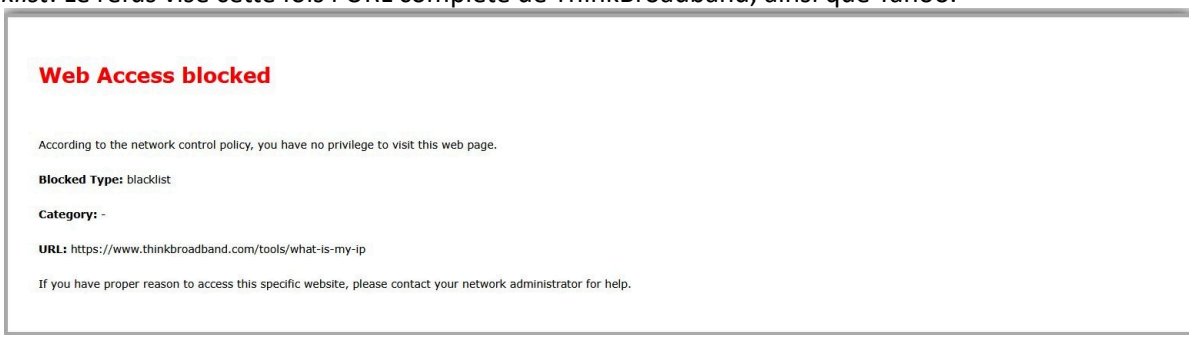


Figure 27. Blocage de l'URL ThinkBroadband incluant le chemin /tools/what-is-my-ip [3].

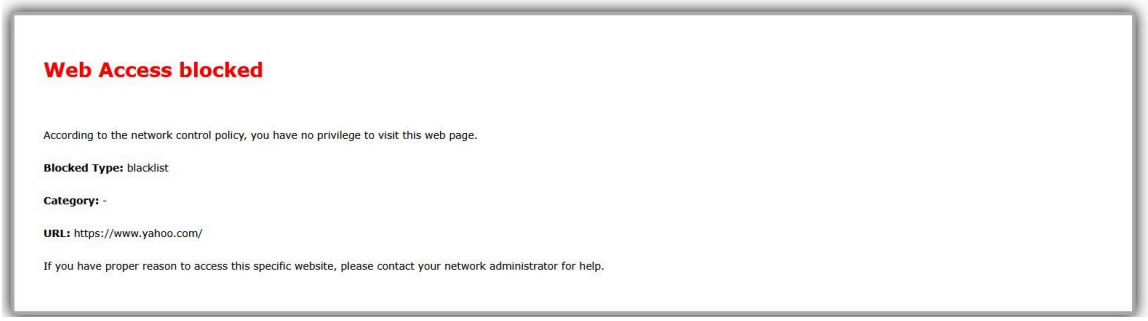


Figure 28. Blocage de Yahoo par la liste noire [3].

Résultat. Le déchiffrement rend le chemin HTTP accessible au moteur de filtrage. Il permet donc un contrôle plus précis que le seul nom d'hôte visible dans le SNI.

XI. Contrôle applicatif de Facebook

Question 30 : règle demandée. La règle `facebook-block` doit s'appliquer de *Trust* vers *Untrust*, avec `Service: any`, les signatures Facebook et l'action `Deny`. Elle doit précéder la règle générale d'autorisation du Web.

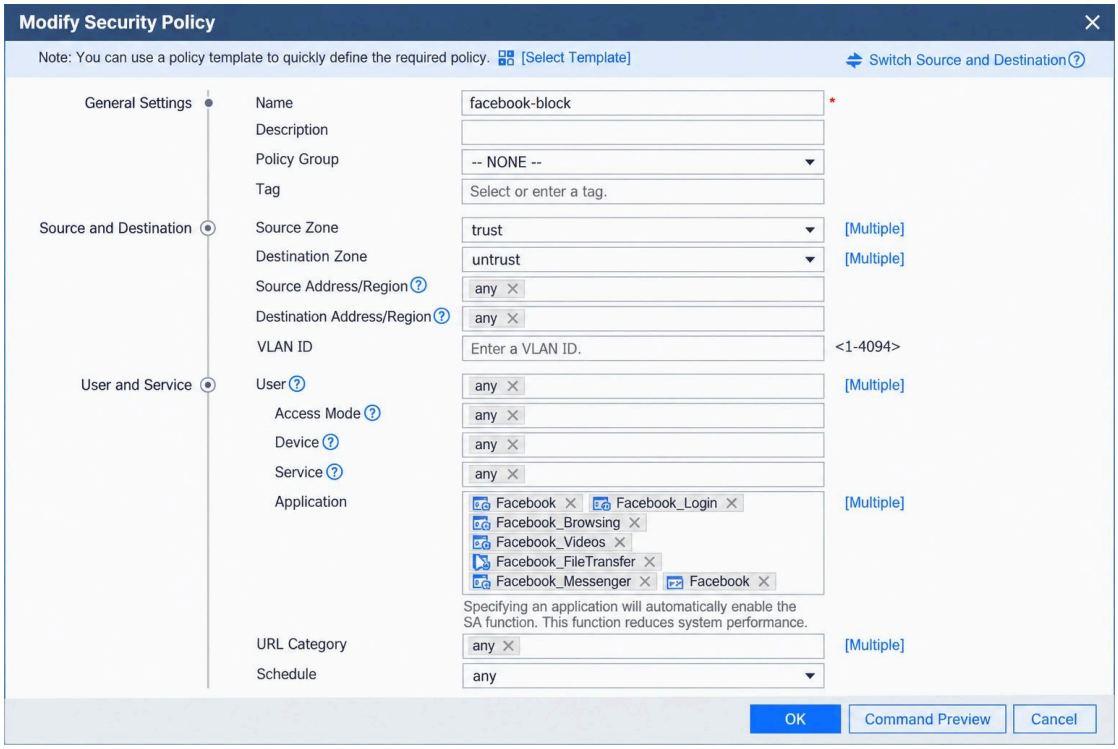


Figure 29. Sélection des signatures applicatives Facebook dans la règle Huawei [3].

La capture montre notamment Facebook, Facebook_Login, Facebook_Browsing, Facebook_Videos, Facebook_FileTransfer et `Facebook_Messenger`. Le champ de l'action n'est pas visible dans cette vue.

Question 31 : tests et résultats attendus. Google doit rester accessible. Les connexions reconnues comme Facebook doivent être bloquées, même si elles utilisent le même port HTTPS que d'autres sites.

Tableau 7. Vérifications demandées pour le contrôle Facebook.

Destination	Résultat attendu
https://www.google.com/	Accès autorisé
https://www.facebook.com	Refus si le flux est identifié Facebook
https://m.facebook.com	Refus si le flux est identifié Facebook
https://business.facebook.com	Refus si le flux est identifié Facebook
https://developers.facebook.com	Refus si le flux est identifié Facebook

Question 32 : validation. La commande `display firewall session table verbose` et les journaux applicatifs permettent de contrôler la classification. La preuve recherchée est une entrée Huawei indiquant l'application Facebook et le refus associé à `facebook-block`. Une session refusée peut être absente de la table des sessions actives.

Résultat disponible. Les signatures sont sélectionnées, mais le blocage Huawei n'est pas confirmé par les documents fournis. La capture de refus présente dans le rapport de référence provient de Fortinet et concerne `fecebook.com`, une adresse différente. Elle ne valide pas le test demandé sur Facebook.